DATA RETENTION AND DISPOSAL PROCESS

SOP-002 | Issued under POL-002 — Data Retention and Disposal Policy

Document ID: SOP-002
Version: 1.0 — DRAFT
Parent Policy: POL-002 — Data Retention and Disposal Policy
Parent Framework: IMF-001 — Information Management Framework
Classification: Internal Use
Owner: Information Security
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Data Retention and Disposal Process
Document ID	SOP-002
Version	1.0 — DRAFT
Status	Draft for Review
Parent Policy	POL-002 — Data Retention and Disposal Policy
Parent Framework	IMF-001 — Information Management Framework
Document Owner	Information Security
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	GDPR Art. 5(1)(e), SOX Section 802, 21 CFR Part 11, EU Annex 11, GxP, HIPAA, CCPA

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This Standard Operating Procedure operationalises POL-002 (Data Retention and Disposal Policy). It defines the step-by-step processes for: assigning retention periods to data assets at classification, managing legal holds that suspend disposal obligations, executing scheduled disposal at end of retention, and responding to unplanned disposal events.

This SOP is the practical reference for all personnel who create, own, or manage data assets — and for IT and Legal teams who implement and govern the controls. It translates the policy obligations into clear, auditable procedures.

2. Scope

This SOP applies to all data assets in scope of POL-002: all formats (electronic, paper, physical media), all systems, all personnel, all jurisdictions. It applies to both Controller and Processor activities under GDPR.

Third parties holding [Company Name] data under contract must comply with the retention and disposal requirements specified in their Data Processing Agreement. Data Owners remain accountable for those obligations.

3. Roles and Responsibilities

Role	Responsibility in This SOP
Data Owner	Assigns and confirms the retention period at classification. Triggers reclassification where data type changes. Approves disposal of assets within their domain.
Data Custodian (IT)	Implements automated retention and deletion schedules in systems. Executes disposal actions. Produces disposal certificates. Suspends deletion on legal hold instruction.
Legal / Compliance	Issues and lifts legal holds. Maintains the Legal Hold Register. Advises on retention period applicability and exceptions. Confirms regulatory minimum periods.
Information Security	Oversees and monitors compliance with retention schedules. Approves third-party disposal vendors. Coordinates annual retention schedule review.
Compliance / QA	Accountable for GxP record retention compliance. Confirms regulatory minimum periods for GxP data categories. Reviews disposal certificates for

Role	Responsibility in This SOP
	GxP records.
Records Management	Where designated: coordinates archival of physical records, manages offsite storage, coordinates physical disposal logistics.

4. Process Trigger Events

This SOP is triggered by the following events:

Trigger	Process Initiated	Section
New data asset classified under SOP-001	Retain Period Assignment — assign retention period at classification	Section 5
Asset reaches end of assigned retention period	Scheduled Disposal — execute secure disposal and produce certificate	Section 6
Litigation, investigation, or regulatory inspection notified	Legal Hold — suspend disposal obligations for specified data	Section 7
Legal hold lifted by Legal / Compliance	Post-Hold Disposal — dispose of any data that has exceeded retention	Section 7.5
Data asset reclassified to different sensitivity tier	Retention Period Review — confirm whether retention period requires update	Section 8
Third-party relationship or system decommissioned	Third-Party / System Disposal — execute disposal per DPA or decommission plan	Section 9
Retention schedule annual review	Schedule Review — validate and update retention periods against current law	Section 10

5. Process A — Retention Period Assignment

This process runs immediately upon completion of the data classification process (SOP-001, Step 7). The retention period is determined at classification and recorded in the Corporate Asset Register before the asset enters production use.

Step 01	**Identify Data Category** The Data Owner, with reference to the completed WI-001 questionnaire and the assigned sensitivity tier, identifies which retention schedule category (or categories) in POL-002 Section 5 applies to the asset. Where an asset spans multiple categories, the longest applicable minimum retention period governs. For GxP data: confirm the specific sub-type (batch record, clinical trial, CSV documentation, etc.) against Table 5.1 in POL-002. GxP minimums are non-negotiable regulatory floors — no business decision may reduce them.	Responsible **Data Owner**
Step 02	**Confirm Regulatory Flags** Check whether the asset carries any regulatory flags assigned during SOP-001 classification: • GxP flag → apply Table 5.1 minimums (overrides all shorter periods) • SOX flag → apply Table 5.2 minimum (7 years for most categories) • Personal data (Tier 4) → apply Table 5.5 and confirm with DPO that the maximum period is compatible with GDPR data minimisation obligations • HIPAA flag → confirm applicable PHI retention period with Legal / Compliance Where multiple flags apply, the longest minimum governs.	Responsible **Data Owner**
Step 03	**Determine Trigger Event** Identify the event that starts the retention period clock. Common trigger events by category: • GxP manufacturing/lab records: trial completion date, batch release date, study completion date • Financial records: financial year end • HR records: employment end date • Clinical trial records: trial completion date • Contracts: contract expiry date • Privacy records: processing cessation or consent withdrawal If the trigger event is in the future, the retention clock does not start until it occurs.	Responsible **Data Owner**
Step 04	**Record Retention Period in Asset Register** The Data Custodian (IT) records the following in the Corporate Asset Register entry for the asset: • Retention category (referencing POL-002 Section 5 table) • Minimum retention period (years) • Maximum retention period (years, or 'Permanent' where applicable) • Trigger event type • Anticipated trigger date (if known) or 'TBC' • Disposal review date (= trigger date + minimum period) • Regulatory flag(s) driving the retention period Where the trigger date is unknown at classification (e.g., employment records for a current employee), set a calendar reminder to update the Asset Register when the trigger event occurs.	Responsible **Data Custodian (IT)**

IMPORTANT: The retention period recorded in the Asset Register is the binding commitment for that asset. It must not be shortened retrospectively without Legal / Compliance approval and documentation of the justification.

Step 05	**Configure System Retention Controls** For assets stored in managed systems, the Data Custodian (IT) configures automated retention controls: • Archive flag: set to auto-archive from active systems to retention archive at the appropriate point • Deletion schedule: configure automated deletion at end of maximum retention period (subject to legal hold status) • Backup inclusion: confirm asset is included in backup schedule per system classification tier For paper and physical assets: record physical storage location and disposal review date in the Asset Register. Engage Records Management to arrange appropriate storage.	Responsible **Data Custodian (IT)**

Step 06	**Notify Stakeholders** Where the retention period has implications for other teams (e.g., a third party holds a copy of the asset; the asset is shared between departments; the asset feeds another system), the Data Owner notifies relevant stakeholders of the retention period and disposal obligations. Third parties must be reminded of their DPA obligations.	Responsible **Data Owner**

6. Process B — Scheduled Disposal

Scheduled disposal is initiated when a data asset reaches the end of its assigned retention period. Disposal must be executed using the approved methods in POL-002 Section 7 and must be documented with a disposal certificate for all Tier 3+ and GxP assets.

Step 01	**Disposal Review Notification** The Asset Register system (or Records Management function) generates a disposal review notification 90 days before the disposal review date recorded for an asset. This notification is sent to the Data Owner and Data Custodian (IT). For manual registers: Information Security coordinates a quarterly review of assets with disposal review dates in the next 90 days.	Responsible **Data Custodian (IT) / Information Security**
Step 02	**Legal Hold Status Check** Before any disposal action is taken, confirm that the asset is not subject to an active legal hold. Legal / Compliance maintains the Legal Hold Register — this must be checked before proceeding. If a legal hold is active: disposal is suspended. Update the Asset Register with the hold reference. No further action until the hold is lifted (see Section 7.5). If no hold is active: proceed to Step 3.	Responsible **Data Owner / Legal / Compliance**
Step 03	**Confirm Disposal Eligibility** The Data Owner confirms: (a) The trigger event has occurred (e.g., employment has ended, contract has expired, trial has completed) (b) The minimum retention period has been met — calculate: trigger date + minimum period ≤ today's date (c) There is no ongoing business need that justifies a documented extension (see Section 11 — Exceptions) (d) For personal data (Tier 4): confirm with DPO that further retention is not justified — GDPR data minimisation requires disposal unless there is a documented legitimate reason to retain If all four criteria are met: proceed to disposal.	Responsible **Data Owner**
Step 04	**Select Disposal Method** Identify the approved disposal method from POL-002 Section 7.1 based on: • Data sensitivity tier (from Asset Register) • Media type (electronic HDD/SSD/USB, cloud/SaaS, backup media, paper, physical device) Key rules: • Tier 3–5 electronic: physical destruction to NIST 800-88, not overwriting alone • Cloud/SaaS: cryptographic erasure + written vendor confirmation of deletion • GxP records: disposal must be documented in the audit trail of the system where the record was held • Paper Tier 3–5: DIN 66399 P-5 shredding by approved vendor	Responsible **Data Custodian (IT)**
Step	**Execute Disposal**	Responsible **Data Custodian**

05	The Data Custodian (IT) executes the disposal using the selected approved method: • Electronic: overwrite/destroy per NIST 800-88 or engage approved destruction vendor • Cloud/SaaS: initiate deletion via platform API or admin console, request vendor deletion confirmation in writing • Paper/physical: engage approved physical destruction vendor or execute in-house shredding per approved standard • Backup media: confirm that all backup copies of the asset are purged from rotation per the backup purge schedule GxP records: record the disposal action in the audit trail of the originating system before destruction.	**(IT)**

Step 06	**Produce Disposal Certificate** A disposal certificate must be produced for: • All Tier 3, Tier 4, and Tier 5 assets regardless of format • All GxP records regardless of sensitivity tier • All physical media destruction events The certificate must include: • Date of disposal • Asset ID and description (from Asset Register) • Sensitivity tier and regulatory flags • Disposal method used • Volume/quantity (number of records, weight of media, etc.) • Name and role of person(s) executing disposal • For third-party vendors: vendor name, vendor certificate/reference number • Signature or digital confirmation of the Data Owner approving disposal	Responsible **Data Custodian (IT) / Data Owner**

Step 07	**Update Asset Register** The Data Custodian (IT) updates the Corporate Asset Register: • Mark the asset status as 'Disposed' • Record the disposal date, method, and disposal certificate reference • Retain the Asset Register entry itself (with disposal record) for 7 years from the disposal date — the record of the asset's existence and disposal is itself a compliance record Notify the Data Owner and Information Security that disposal is complete.	Responsible **Data Custodian (IT)**

NOTE: Disposal certificates must be retained for 7 years regardless of the sensitivity tier of the data disposed of. The certificate is a compliance record in its own right.

7. Process C — Legal Hold

A legal hold suspends all disposal obligations for specified data pending or in anticipation of litigation, regulatory investigation, or regulatory inspection. Legal holds override retention schedules — no data subject to an active hold may be disposed of regardless of whether its retention period has expired.

7.1 Issuing a Legal Hold

Step 01	**Identify Hold Scope** Legal / Compliance identifies the trigger event (litigation, investigation, inspection notice, internal escalation) and determines the scope of data to be held: • Categories of data affected • Date range of records • Systems holding the data • Custodians (individuals or teams) holding the data The scope must be as specific as possible — an overly broad hold creates unnecessary cost and complexity. An insufficiently specific hold creates legal risk.	Responsible **Legal / Compliance**
Step 02	**Issue Legal Hold Notice** Legal / Compliance prepares and issues a written Legal Hold Notice to all named custodians and Data Owners within 1 business day of identifying the hold trigger. The Notice must include: • Reference number (LH-YYYY-NNN format) • Description of the matter requiring the hold • Scope: categories of data, date range, systems • Named custodians • Instructions: do not delete, do not destroy, do not modify • Contact at Legal / Compliance for questions All recipients must acknowledge in writing within 2 business days.	Responsible **Legal / Compliance**
Step 03	**Suspend Deletion Schedules** Upon receipt of the Legal Hold Notice, the Data Custodian (IT) immediately: • Suspends all automated deletion schedules for data in scope • Suspends backup purge rotations for systems holding in-scope data • Flags the affected Asset Register entries with the hold reference number • Confirms suspension to Legal / Compliance in writing within 1 business day For cloud/SaaS systems: disable any auto-delete or data lifecycle policies within the platform for the affected data.	Responsible **Data Custodian (IT)**
Step 04	**Register the Hold** Legal / Compliance records the legal hold in the Legal Hold Register: • Hold reference number • Date issued • Triggering matter and brief description • In-scope systems and custodians • Date of all custodian acknowledgements • Quarterly review dates The Legal Hold Register is a controlled document. Access is restricted to Legal / Compliance, Information Security, and senior leadership on a need-to-know basis.	Responsible **Legal / Compliance**

7.2 Maintaining a Legal Hold

Step 05	**Quarterly Hold Review** Legal / Compliance reviews each active hold quarterly: • Confirm the matter remains active and the hold remains necessary • Confirm that no new custodians or data categories should be added • Confirm that no custodians or data categories can be removed (partial release) • Re-issue a hold reminder to custodians annually if the hold remains in force Update the Legal Hold Register with each review date and outcome.	Responsible **Legal / Compliance**

7.3 Hold for Regulatory Inspections

GxP: Where a regulatory inspection is announced (GxP, SOX, privacy authority), Legal / Compliance and Compliance / QA jointly assess whether a targeted hold is appropriate. Inspection-related holds typically cover: records within the inspection scope, audit trails, validation documentation, and correspondence with the authority. The hold is maintained until the inspection is closed and any follow-up actions are completed.

7.4 Releasing a Legal Hold

Step 06	**Issue Release Notice** When the matter is resolved (litigation settled, investigation closed, inspection complete with no outstanding actions), Legal / Compliance issues a written Legal Hold Release Notice to all original custodians: • Hold reference number • Confirmation that the matter is resolved • Date the hold is lifted • Instructions: normal retention and disposal obligations resume Update the Legal Hold Register with the release date and closure reason.	Responsible **Legal / Compliance**

7.5 Post-Hold Disposal

Step 07	**Dispose of Overdue Assets** Upon receipt of the Release Notice, the Data Custodian (IT) identifies any assets that: (a) Were subject to the hold (b) Had exceeded their retention period at the time of the hold or during the hold period These assets must be disposed of promptly following the normal Scheduled Disposal process (Section 6) — they should not be retained further simply because they were held. Legal / Compliance confirms which assets are eligible for disposal. Execute disposal within 30 days of the Release Notice.	Responsible **Data Custodian (IT) / Legal / Compliance**

8. Process D — Retention Review on Reclassification

When a data asset is reclassified to a different sensitivity tier (per SOP-001 reclassification process), the Data Owner must assess whether the reclassification changes the applicable retention category and therefore the retention period.

Reclassification Event	Retention Review Action
Upward reclassification (e.g., Tier 2 → Tier 4 — Sensitive Personal)	DPO must confirm whether a GDPR retention period now applies that is shorter than the current retention period. If so, the retention period must be updated and disposal may need to be brought forward (with DPO approval).
Downward reclassification (e.g., Tier 4 → Tier 2)	Confirm whether GxP, SOX, or other regulatory minimum periods still apply. If not, the retention period may be reduced. Update the Asset Register. Automated deletion schedules must be reconfigured.
Addition or removal of GxP flag	GxP flag added: apply GxP minimum retention period from POL-002 Table 5.1 immediately — this overrides any shorter period previously recorded. GxP flag removed: revert to the applicable non-GxP category minimum.
Addition or removal of SOX flag	SOX flag added: apply 7-year minimum immediately. SOX flag removed: revert to applicable non-SOX category minimum, confirmed with Legal / Compliance.

Any retention period update must be documented in the Asset Register as a reclassification event, with the date, reason, and approver recorded.

9. Process E — Third-Party and System Decommissioning Disposal

When a third-party relationship ends or a system is decommissioned, all data held by that party or system must be disposed of or migrated in accordance with POL-002 and the applicable Data Processing Agreement.

9.1 Third-Party Offboarding

Step 01	**Identify In-Scope Data** The Data Owner (with input from the procurement / vendor management function) identifies all [Company Name] data held by the departing third party. This includes primary data, backup copies, and any data derivatives.	Responsible **Data Owner**

Step 02	**Confirm DPA Obligations** Legal / Compliance confirms the disposal obligations set out in the relevant DPA: • Does [Company Name] require return of data before disposal? If so, initiate data return first. • What is the timeframe for disposal after relationship end? • Is a disposal certificate required? (Standard requirement for Tier 3+ and GxP data.)	Responsible **Legal / Compliance**
Step 03	**Obtain Disposal Confirmation** The vendor must provide written confirmation of disposal — typically a disposal certificate or deletion confirmation letter — within the timeframe specified in the DPA. Information Security reviews and approves the confirmation before the vendor file is closed. The confirmation is retained in the vendor record for 7 years.	Responsible **Information Security / Data Owner**

9.2 System Decommissioning

NOTE: System decommissioning triggers data disposal obligations for all data held in the decommissioned system. The decommission plan (governed by SOP-005 and POL-007 — Change Management Policy) must include a data disposal schedule as a mandatory component. For GxP systems (Track A per POL-006): decommissioning additionally requires a Validation Closure Report from Compliance / QA and archival of the Validation Master File. These obligations are described in Step 4a below.

Step 4a	**Track A — Validation Closure (GxP systems only)** Before a GxP-validated system (Track A per POL-006) is shut down, the following must be completed: (i) Compliance / QA issues a Validation Closure Report confirming: — The system is being formally retired — All GxP data has been migrated to an approved successor system or disposed of per this SOP — The audit trail is archived and accessible for the retention period applicable to the records it covers — Any open CAPAs have been closed or transferred to the successor system (ii) The Validation Master File (VMF) is archived in the quality management system. The VMF must remain accessible for inspection for the life of the product or study plus the applicable retention period (see POL-002 Table 5.1 — CSV documentation: life of system + 5 years from decommission date). (iii) The Compliance / QA archive confirmation is provided to Information Security before the system is shut down. Note: Audit trail records must be migrated or archived alongside the primary records they relate to. An audit trail left in a decommissioned system is inaccessible to inspectors and constitutes a data integrity failure.	Responsible **Compliance / QA / System Owner**
Step 04	**Decommission Data Disposal** The System Owner and Data Custodian (IT), with Data Owner input: (a) Identify all data assets held in the system from the Asset Register (b) For each asset: confirm whether it is still within its retention period — If yes: migrate to an approved alternative system before decommissioning — If	Responsible **System Owner / Data Custodian (IT) / Data Owner**

	no, and no legal hold: execute disposal per Section 6 (c) Produce disposal certificates for all assets disposed of (d) Update the Asset Register — mark all disposed assets as 'Disposed' with reference to the decommissioning event (e) For Track A systems: confirm Validation Closure Report (Step 4a) is complete before issuing shut-down confirmation (f) Confirm to Information Security that all data has been migrated or disposed of and all validation documentation archived before the system is shut down	

10. Process F — Annual Retention Schedule Review

The retention schedule in POL-002 Section 5 must be reviewed annually by Information Security and Compliance / QA to ensure it reflects current regulatory requirements. This review is coordinated by Information Security and runs concurrently with the annual IMF review cycle.

Step	Action	Responsible
1	Information Security initiates the review and circulates the current retention schedule to Compliance / QA, Legal / Compliance, and the DPO for input.	Information Security
2	Compliance / QA reviews all GxP categories against current regulatory guidance (FDA, EMA, MHRA, ICH). Notes any changes to minimum periods.	Compliance / QA
3	Legal / Compliance reviews financial, HR, and commercial categories against current legislation in all jurisdictions where [Company Name] operates.	Legal / Compliance
4	DPO reviews all personal data categories against current GDPR guidance and supervisory authority decisions.	DPO
5	Information Security consolidates inputs, identifies changes, and updates POL-002 if required. Material changes to retention periods trigger an update to the Asset Register for affected asset categories.	Information Security
6	Updated POL-002 is approved per the IMF change management process and distributed to all Data Owners.	CIO / Information Security

11. Exceptions

Exceptions to the retention schedule — retaining data beyond its maximum period or disposing before its minimum — must be submitted in writing to Information Security and approved by the Data Owner, Information Security, and Legal / Compliance.

Exception Type	Approval Required	Documentation
Retain beyond maximum period (non-GxP, non-personal data)	Data Owner + Information Security + Legal / Compliance	Written justification + approved Exception Record in Asset Register
Retain beyond maximum period (personal data)	Data Owner + DPO + Information Security	DPO must confirm GDPR data minimisation is not breached. DPIA may be required.
Dispose before minimum period (non-GxP)	Data Owner + Legal / Compliance +	Written justification. Legal / Compliance confirms no regulatory breach.

Exception Type	Approval Required	Documentation
	Information Security	
Dispose before minimum period (GxP data)	Not permitted	GxP regulatory minimum periods cannot be waived. Escalate to Compliance / QA and Legal if there is a genuine operational need — regulatory authority advice may be required.

12. Records Generated by This SOP

Record	Storage Location	Retention Period	Responsible
Corporate Asset Register entries (including retention period and disposal record)	Corporate Asset Register	7 years from disposal date	Data Custodian (IT)
Disposal certificates (Tier 3 –5 and GxP)	Document management system / vendor file	7 years from disposal date	Data Custodian (IT)
Legal Hold Notices and acknowledgements	Legal Hold Register	7 years from hold release date	Legal / Compliance
Legal Hold Release Notices	Legal Hold Register	7 years from release date	Legal / Compliance
Third-party disposal confirmations	Vendor record	7 years from receipt	Information Security
Exception records	Exception Register	7 years from creation	Information Security
Annual schedule review output	IMF review archive	7 years	Information Security

13. Related Documents

Document ID	Title	Relationship
POL-002	Data Retention and Disposal Policy	Parent policy — mandatory requirements this SOP operationalises
POL-001	Data Classification Policy	Sensitivity tier from classification drives disposal method selection

Document ID	Title	Relationship
POL-003	Data Integrity Policy	GxP audit trail records must be retained and disposed per this SOP alongside primary records
POL-004	Privacy Policy	GDPR data minimisation governs maximum retention of personal data
POL-005	System Classification Policy	System decommissioning triggers data disposal obligations covered in Section 9
POL-006	Computer System Validation and Qualification Policy	Track A (GxP) system decommissioning requires a Validation Closure Report and VMF archival per Section 9.2 of this SOP
POL-007	Change Management Policy	System decommissioning is a controlled change; the decommission plan must include a data disposal and validation closure schedule
POL-008	Access Control Policy	Disposal execution, legal hold suspension, and Asset Register updates require authenticated, auditable access by authorised individuals; access to disposal tooling is governed by POL-008
POL-012	Incident Response Policy	Data breach may trigger legal hold; breach notification timeline intersects with retention
POL-013	Third Party and Vendor Risk Policy	Third-party disposal vendor requirements; DPA obligations
SOP-001	Data Classification Process	Retention period assigned at Step 7 of SOP-001 — feeds into Section 5 of this SOP
SOP-005	System Classification Process	System decommissioning checklist references this SOP for data disposal
RACI-001	Roles, Responsibilities and Authorities	Accountability for retention and disposal activities

14. Definitions

Term	Definition
Disposal Certificate	Written evidence that a data asset or storage medium has been destroyed using an approved method, including date, method, volume, and responsible party.
Legal Hold	A formal directive issued by Legal / Compliance that suspends normal data disposal obligations for specified data pending litigation, investigation, or regulatory inspection.
Legal Hold Register	The controlled register maintained by Legal / Compliance recording all active and historical legal holds, including scope, custodians, and status.

Term	Definition
Retention Period	The defined timeframe during which a data asset must be kept. Comprises a minimum (regulatory floor) and maximum (data minimisation ceiling or policy limit).
Trigger Event	The event that starts the clock on a retention period (e.g., record closure, employment end, contract expiry, trial completion).

— End of Document —

SOP-002 v1.0 DRAFT | [Company Name] | CONFIDENTIAL